

Task 4

Executive summary

In this Task I was able to find a semi secured site that let me use my experience from our before done task 1-3 to test and see how secured the site may be. I had founded a really huge vulnerability at the end of the task when I was able to go into the admin panel which showed all the username, password, and social security number. This prove that although the site may be secured against the basic sql injection, and xss basic script it is not all thought out to be secured as there is some flaw in the website although not as much as the juice website we had done before burpsuite and owasp zap during this task has let me learn so much more about how vulnerability could be easily detected by attackers or how your information can be easily stolen just because of an outdated system or end of life service.

Testing methodology

Nmap, nikto, Owasp zap, and burpsuite

Identified vulnerability

-We had identified that the main webpage of webappsecurity has a huge vulnerability of letting user be able to access the main admin easily gaining full access to user's account, password , and most importantly their own social security number a malicious attacker can then use these information and especially with a social security number can disguise themselves and steal the customer's identity causing legal concern and lawsuits.

- port 8080 open
- End of life OpenSSL version
- Old httpd from 2007
- insecure http method
- access control policy not secured

Proof of concept

In this nmap scan I found out they're still using apache httpd 2.2.6 which was released back in 2007 causing high risk as since it's known to have security issues and since this is a old version attackers can exploit it easily. Another thing is that they're using OpenSSL/0.9.8e mod_jk/1.2.40 which is a no longer supported and updated so they're more vulnerable to modern day attacks. Port 8080 is also another vulnerability since it is generally less protected so when it is open attackers will generally attack it.

```

(tonytrankiller@Tony)-[~]
$ nmap -sS -sV -Pn -T4 zero.webappsecurity.com -oN nmap_report.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-02 15:09 -0500
Stats: 0:00:13 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Nmap scan report for zero.webappsecurity.com (54.82.22.214)
Host is up (0.055s latency).
rDNS record for 54.82.22.214: ec2-54-82-22-214.compute-1.amazonaws.com
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http Apache httpd 2.2.6 ((Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e mod_jk/1.2.40)
8080/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.80 seconds

```

In this nikto scan it seems that there is a insecure http method since the PUT and DELETE are enable so any attacker can manipulate the files. The access control allowed origin is set to * which allows any domain to access it.

```

(tonytrankiller@Tony)-[~]
$ nikto -h http://zero.webappsecurity.com -output nikto_report.txt
Nikto v2.5.0
+ Target IP: 54.82.22.214
+ Target Hostname: zero.webappsecurity.com
+ Target Port: 80
+ Start Time: 2026-01-02 15:28:57 (GMT-5)

+ Server: Apache-Coyote/1.1
+ /: Retrieved access-control-allow-origin header: *.
+ /: The anti-clickjacking X-Frame-options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /: Server banner changed from 'Apache-Coyote/1.1' to 'Apache/2.2.6 (Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e mod_jk/1.2.40'.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, TRACE, OPTIONS, PATCH.
+ HTTP method (Allow header): 'PUT' method could allow clients to save files on the web server.
+ HTTP method (Allow header): 'DELETE' may allow clients to remove files on the web server.
+ HTTP method: 'PATCH' may allow client to issue patch commands to server. See RFC-5789.
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561
+ /admin/: This might be interesting.
+ /readme.txt: Uncommon header 'content-disposition' found, with contents: attachment; filename='readme.txt'.
+ /readme.txt: This might be interesting.
+ /admin/index.html: Admin login page/section found.
+ /login.html: Admin login page/section found.
+ /manager/html: Default Tomcat Manager / Host Manager interface found.
+ /manager/status: Default Tomcat Server Status interface found.
+ /web-config.php: Web-config.php file found. This file contains the credentials.
+ 20619 requests: 0 error(s) and 17 item(s) reported on remote host
+ End Time: 2026-01-02 15:39:14 (GMT-5) (617 seconds)

+ 1 host(s) tested

```

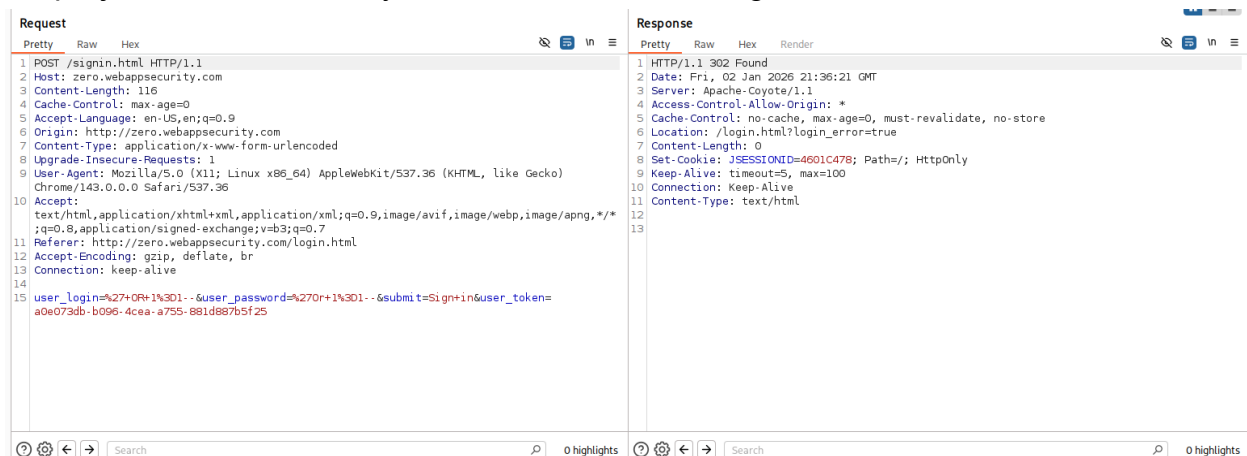
In the actual file of the owasp zap .pdf it shows the results of the report although there isn't any high severity vulnerability like when we did the juice site this one is a bit more secured with things like the basic xss and sql injection being secured.

History	Search	Alerts	Output	Spider	AJAX Spider	Active Scan	Current Scans: 0	URLs Found: 24	Nodes Added: 13	Export
New Scan	Progress: 0	http://zero.webappsecurity.com/	100%							
URLs	Added Nodes	Messages	Processed	Method	URI	Flags				
			●	GET	http://zero.webappsecurity.com/	Seed				
			●	GET	http://zero.webappsecurity.com/robots.txt	Seed				
			●	GET	http://zero.webappsecurity.com/sitemap.xml	Seed				
			●	GET	http://zero.webappsecurity.com/index.html					
			●	GET	https://www.microfocus.com/about/legal/	Out of Scope				
			●	GET	http://zero.webappsecurity.com/resources/css/bootstrap.min.css					
			●	GET	http://zero.webappsecurity.com/resources/css/font-awesome.css					
			●	GET	http://zero.webappsecurity.com/resources/css/main.css					
			●	GET	http://zero.webappsecurity.com/resources/js/jquery-1.8.2.min.js					
			●	GET	http://zero.webappsecurity.com/resources/js/bootstrap.min.js					
			●	GET	http://zero.webappsecurity.com/resources/js/placeholders.min.js					
			●	GET	http://zero.webappsecurity.com/resources/img/main_carousel_1.jpg					
			●	GET	http://zero.webappsecurity.com/resources/img/main_carousel_2.jpg					
			●	GET	http://zero.webappsecurity.com/resources/img/main_carousel_3.jpg					
			●	GET	http://zero.webappsecurity.com/search.html?searchTerm=ZAP					
			●	GET	http://fortawesome.github.com/Font-Awesome/	Out of Scope				
			●	GET	http://scripts.sil.org/OFL	Out of Scope				
			●	GET	http://opensource.org/licenses/mit-license.html	Out of Scope				
			●	GET	http://creativecommons.org/licenses/by/3.0/	Out of Scope				
			●	GET	http://fortawesome.github.com/Font-Awesome	Out of Scope				
			●	GET	http://twitter.com/fortawesome_me	Out of Scope				
			●	GET	http://kynus.com/	Out of Scope				
			●	GET	http://www.apache.org/licenses/LICENSE-2.0.txt	Out of Scope				
			●	GET	http://www.apache.org/licenses/LICENSE-2.0	Out of Scope				

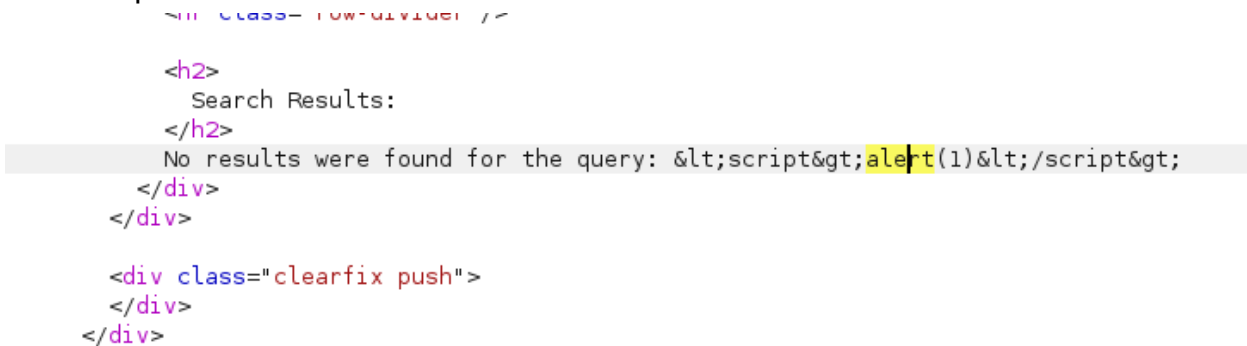
<https://drive.google.com/file/d/10xml1z3oplzc3LA30--yi-OaFIXX9nT/view?usp=sharing>

Burpsuite:

The website in the photo shown below looked like it caught on with the sql injection when it said login_error = true this mean that the website knows that we had tried to do a sql injection and had deny it when we did it meaning the website is secured.



I had tried using a common xss script `<script>alert(1)</script>` which seemed to have been replacing the `<` and `>` keys into `<` and `>` which then prevents anyone from using a xss script.

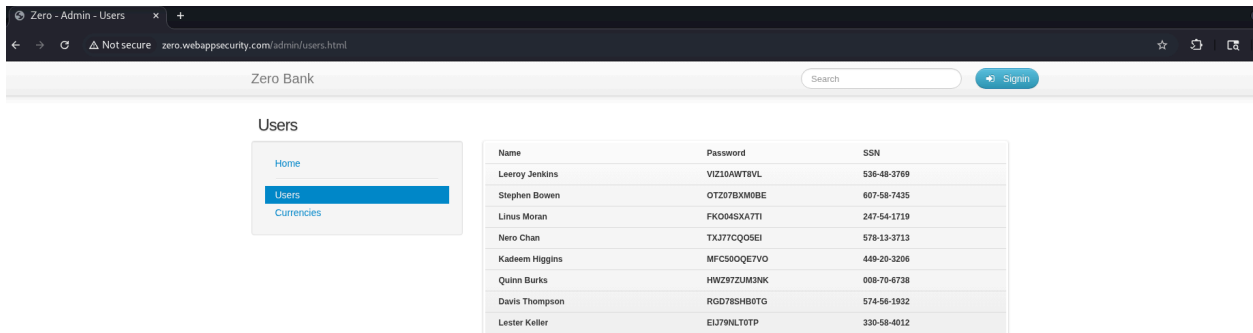


Below it shows that the cookie has a Httponly which prevents Xss script from stealing the cookie it also has a vulnerability which is it is missing a secure flag which can let attackers can check out your cookie in plain text which is another vulnerability of this site.

Response

```
Pretty  Raw  Hex  Render
1 HTTP/1.1 302 Found
2 Date: Fri, 02 Jan 2026 21:36:21 GMT
3 Server: Apache-Coyote/1.1
4 Access-Control-Allow-Origin: *
5 Cache-Control: no-cache, max-age=0, must-revalidate, no-store
6 Location: /login.html?login_error=true
7 Content-Length: 0
8 Set-Cookie: JSESSIONID=4601C478; Path=/; HttpOnly
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html
```

I was able to get into the admin control panel by using /admin at the end of the website url it turns out although the site was secured in many ways the one flaw they had was not blocking user from being able to access the admin privilege page that then showed a Huge vulnerability in which it showed the user name and password but most of all their social security number this in it's own term is one of the biggest issue a bank can have is letting attackers steal people social numbers this easily which can cause a huge lawsuit later on if found out about the insecurity measure the site had taken.



Conclusion & recommendation

I recommend that the site will get a whole renewal and up to date version where user data are protected in a process where the admin control panel is not easily accessible, and how they stop using end of life services that no longer are supported.

Appendice & logs

```
# Nmap 7.98 scan initiated Fri Jan  2 15:09:27 2026 as:
/usr/lib/nmap/nmap --privileged -sS -sV -Pn -T4 -oN
nmap_report.txt zero.webappsecurity.com
Nmap scan report for zero.webappsecurity.com (54.82.22.214)
Host is up (0.055s latency).
rDNS record for 54.82.22.214:
ec2-54-82-22-214.compute-1.amazonaws.com
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1
443/tcp   open  ssl/http  Apache httpd 2.2.6 ((Win32)
mod_ssl/2.2.6 OpenSSL/0.9.8e mod_jk/1.2.40)
8080/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1

Service detection performed. Please report any incorrect results
at https://nmap.org/submit/ .
# Nmap done at Fri Jan  2 15:09:48 2026 -- 1 IP address (1 host
up) scanned in 21.80 seconds
```

- Nikto v2.5.0/

```
+ Target Host: zero.webappsecurity.com
+ Target Port: 80
+ GET /: Retrieved access-control-allow-origin header: *.
+ GET /: The anti-clickjacking X-Frame-Options header is not
present. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Fram
e-Options:
+ GET /: The X-Content-Type-Options header is not set. This
could allow the user agent to render the content of the site in
a different fashion to the MIME type. See:
https://www.netsparker.com/web-vulnerability-scanner/vulnerabili
ties/missing-content-type-header/:
+ GET : Server banner changed from 'Apache-Coyote/1.1' to
'Apache/2.2.6 (Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e
mod_jk/1.2.40'.
+ OPTIONS OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT,
DELETE, TRACE, OPTIONS, PATCH .
+ GET HTTP method ('Allow' Header): 'PUT' method could allow
clients to save files on the web server.
```

+ GET HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.

+ GET HTTP method: 'PATCH' may allow client to issue patch commands to server. See RFC-5789.

+ GET /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561:

+ GET /admin/: This might be interesting.

+ GET /readme.txt: Uncommon header 'content-disposition' found, with contents: attachment; filename="readme.txt".

+ GET /readme.txt: This might be interesting.

- Nikto v2.5.0/

+ Target Host: zero.webappsecurity.com

+ Target Port: 80

+ GET /: Retrieved access-control-allow-origin header: *.

+ GET /: The anti-clickjacking X-Frame-Options header is not present. See:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>:

+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See:
<https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/>:

+ GET : Server banner changed from 'Apache-Coyote/1.1' to 'Apache/2.2.6 (Win32) mod_ssl/2.2.6 OpenSSL/0.9.8e mod_jk/1.2.40'.

+ OPTIONS OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, PUT, DELETE, TRACE, OPTIONS, PATCH .

+ GET HTTP method ('Allow' Header): 'PUT' method could allow clients to save files on the web server.

+ GET HTTP method ('Allow' Header): 'DELETE' may allow clients to remove files on the web server.

+ GET HTTP method: 'PATCH' may allow client to issue patch commands to server. See RFC-5789.

+ GET /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561:

+ GET /admin/: This might be interesting.

+ GET /readme.txt: Uncommon header 'content-disposition' found, with contents: attachment; filename="readme.txt".

+ GET /readme.txt: This might be interesting.
+ GET /admin/index.html: Admin login page/section found.
+ GET /login.html: Admin login page/section found.
+ GET /manager/html: Default Tomcat Manager / Host Manager interface found.
+ GET /manager/status: Default Tomcat Server Status interface found.
+ GET /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.